



FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

ROAD TO HALL OF FAME



BRYHAN EDUARDO GUZMAN MARTINEZ

178508

SEGURIDAD INFORMÁTICA

Índice

1. Explicación Técnica de la Vulnerabilidad	2
2. Explicación Técnica del Payload Utilizado	2
3. Evidencias y Capturas de Pantalla	3
4. Mitigaciones Recomendadas	8

1. Explicación Técnica de la Vulnerabilidad

Esta vulnerabilidad ocurre cuando una aplicación web utiliza entradas proporcionadas por el usuario para construir rutas de acceso a archivos en el sistema operativo sin realizar una validación o sanitización adecuada.

En este escenario particular, la aplicación intenta defenderse filtrando las secuencias comunes de salto de directorio (como ../ o %2f). Sin embargo, el servidor realiza un proceso de **URL-decode superfluo o recursivo** después de haber aplicado el filtro de seguridad inicial. Al realizar la sanitización sobre la entrada en bruto (raw) y posteriormente decodificarla antes de pasarla al sistema de archivos, se genera una falla lógica de secuencia que permite evadir la restricción mediante codificación doble (*Double URL Encode*).

2. Explicación Técnica del Payload Utilizado

- **Payload utilizado:** ../%252f../%252f../%252fetc/passwd
- **Funcionamiento paso a paso:**
 1. **Codificación del carácter /:** El carácter de barra diagonal / codificado en URL estándar es %2f.
 2. **Doble codificación:** Al aplicar URL-encode al símbolo %, la secuencia %2f se transforma en %252f (donde %25 representa el carácter %).
 3. **Evasión del filtro:** Cuando la solicitud llega a la aplicación, el filtro de seguridad busca secuencias como ../ o ../%2f. Como encuentra ../%252f, no la detecta como una amenaza y la deja pasar.
 4. **Decodificación del servidor:** Posteriormente, el backend realiza una decodificación URL sobre la cadena:

../%252f../%252f../%252f../
 5. **Acceso al archivo:** La ruta final procesada se traduce como ../../../../etc/passwd, lo que permite retroceder en la estructura de directorios hasta la raíz del sistema de archivos y leer /etc/passwd.

3. Evidencias y Capturas de Pantalla

Lab: File path traversal, traversal sequences stripped with superfluous URL-decode

PRACTITIONER

LAB Not solved

This lab contains a path traversal vulnerability in the display of product images.

The application blocks input containing path traversal sequences. It then performs a URL-decode of the input before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

Imagen 1. Tenemos el laboratorio 1 Lab: File path traversal, traversal sequences stripped with superfluous URL-decode, primero hacemos click en “ACCESS THE LAB”

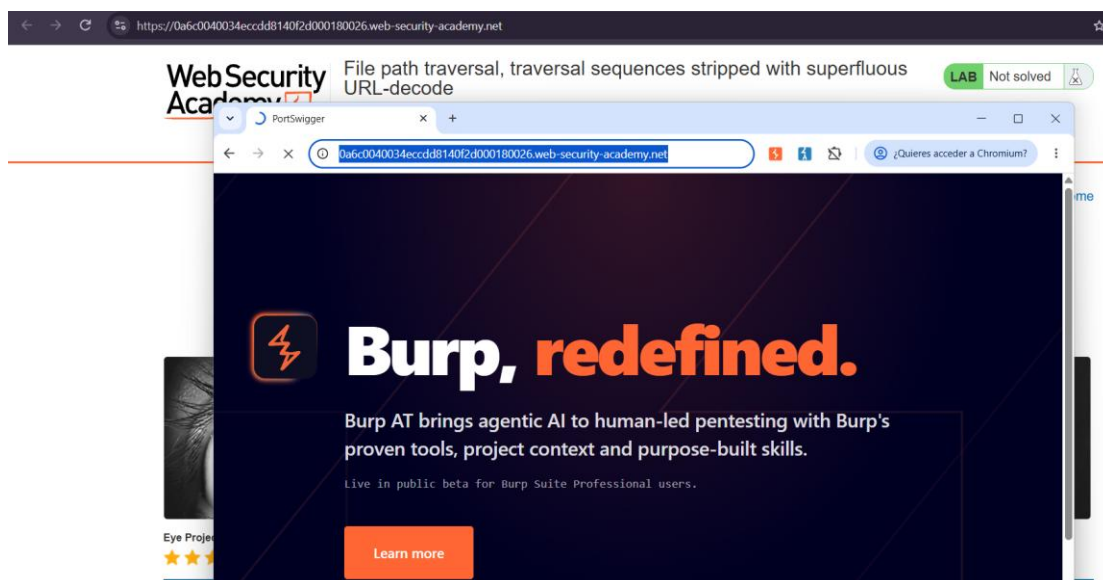


Imagen 2. Nos abre una página que nos arroja un URL el cual tenemos que copiar

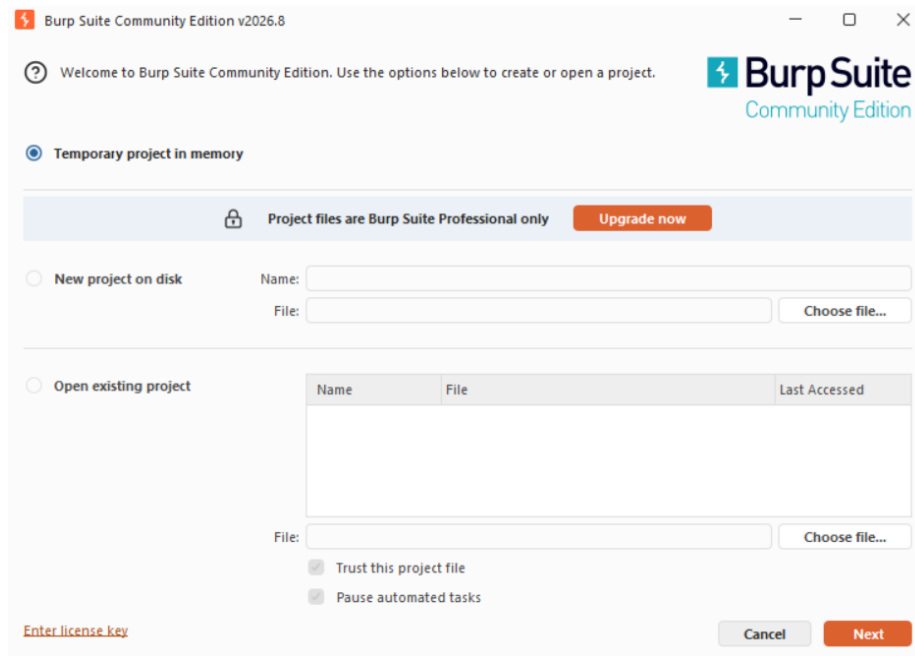


Imagen 3. Abrimos BurpSuit previamente descargado, seleccionamos “Temporary Project in memory”, después demos click en “Next”

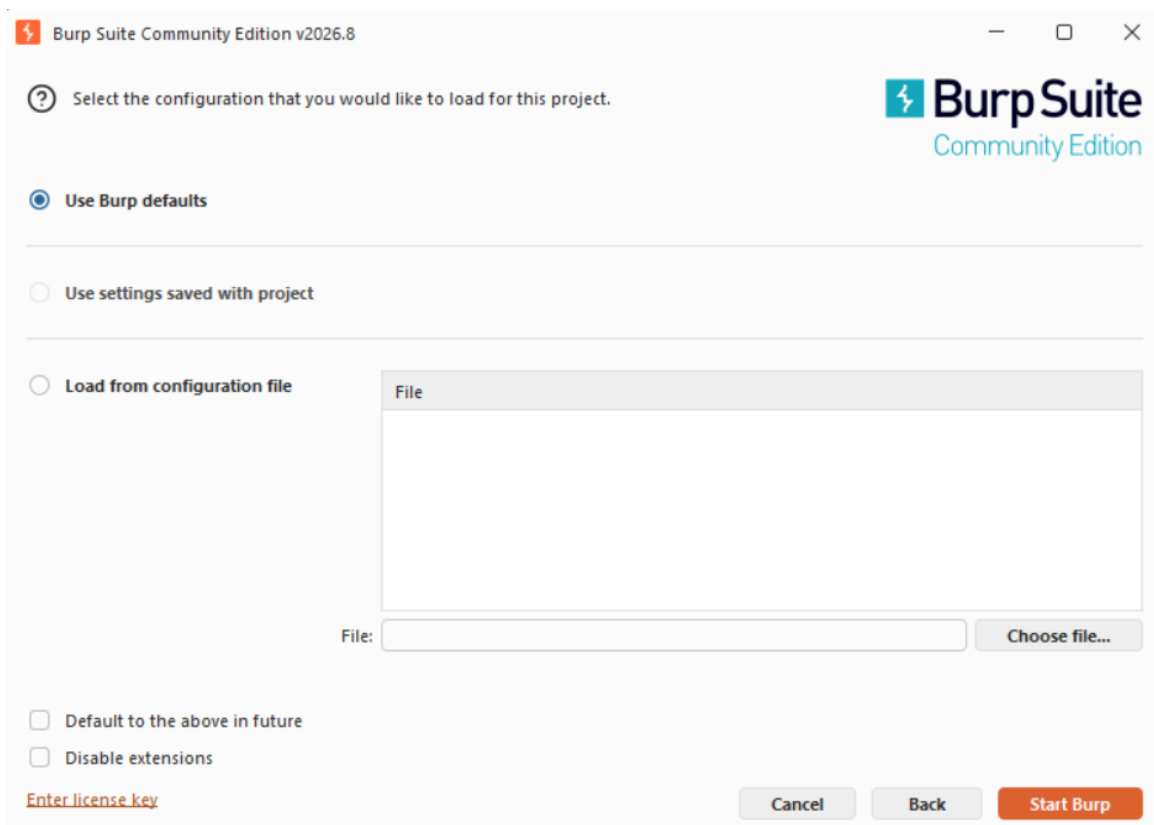


Imagen 4. Seleccionamos “Use Burp defaults” y damos click en “Start Burp”.

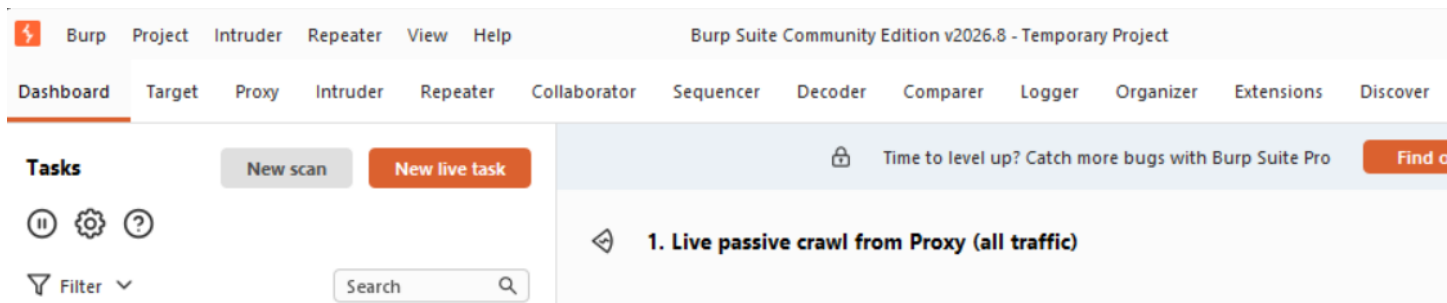


Imagen 5. El las pesañas que están arriba, daremos click en “Proxy”

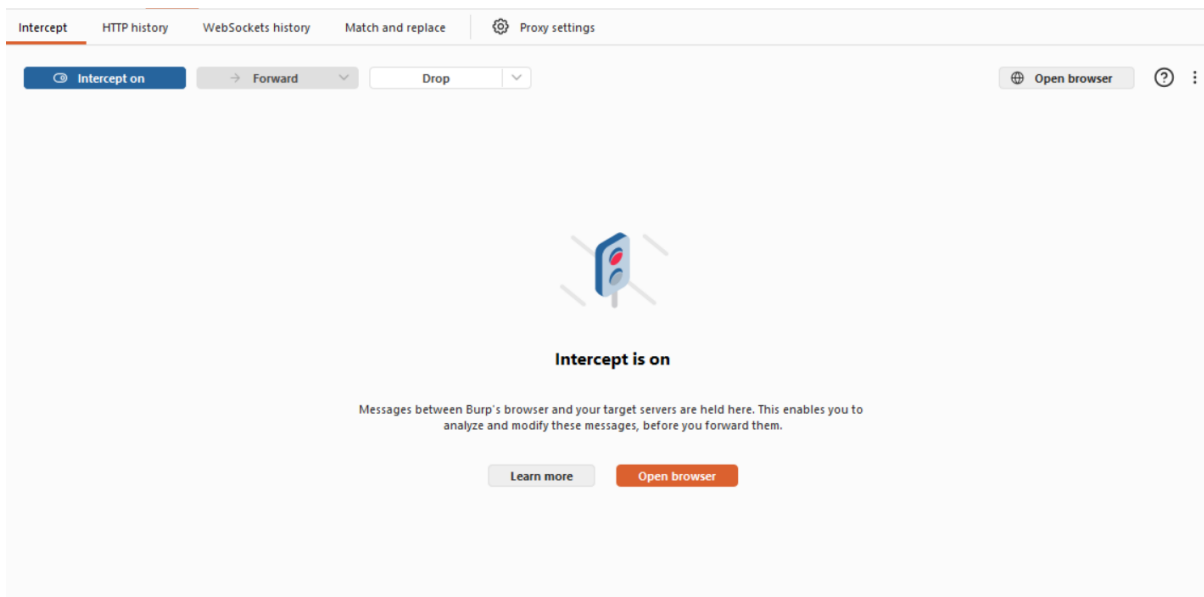


Imagen 6. Daremos click en “Intercept on” para que cambie a “Intercept off” después daremos click en open browser.

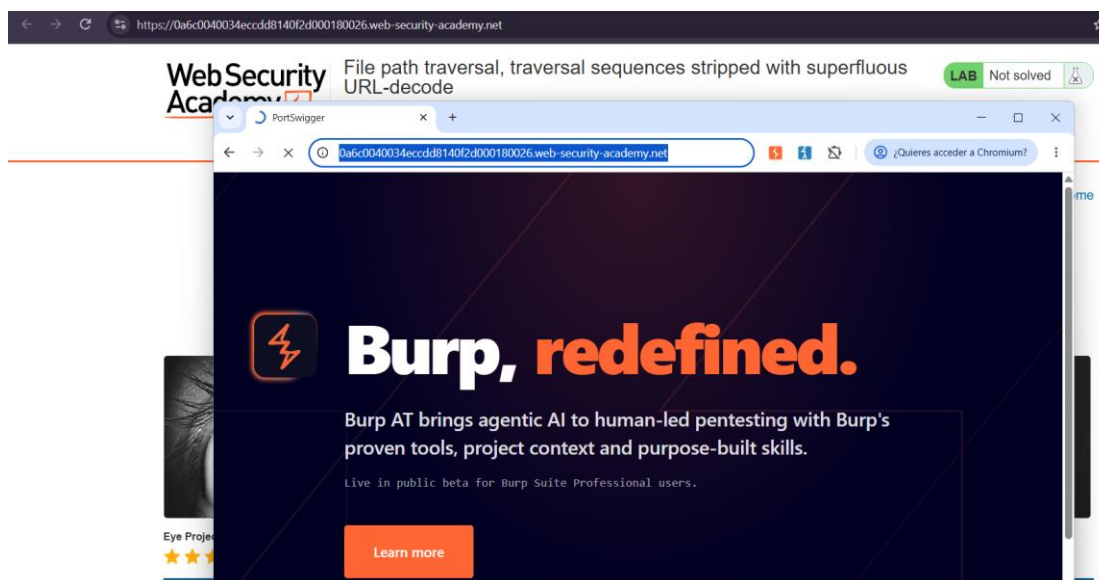


Imagen 7. Se abrirá una pestaña del navegador donde pegaremos la URL que nos dieron cuando accedimos al laboratorio (imagen 2)

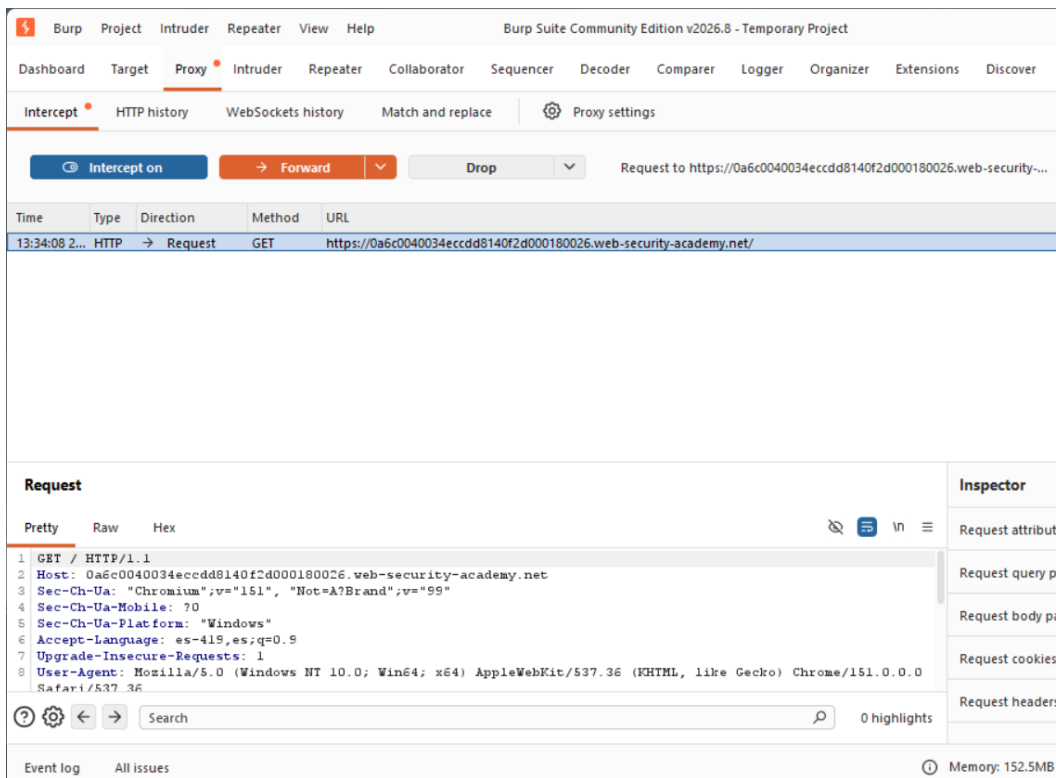


Imagen 8. En BurpSuite nos aparecerá un archivo HTTP, donde presionaremos “FOWARD”

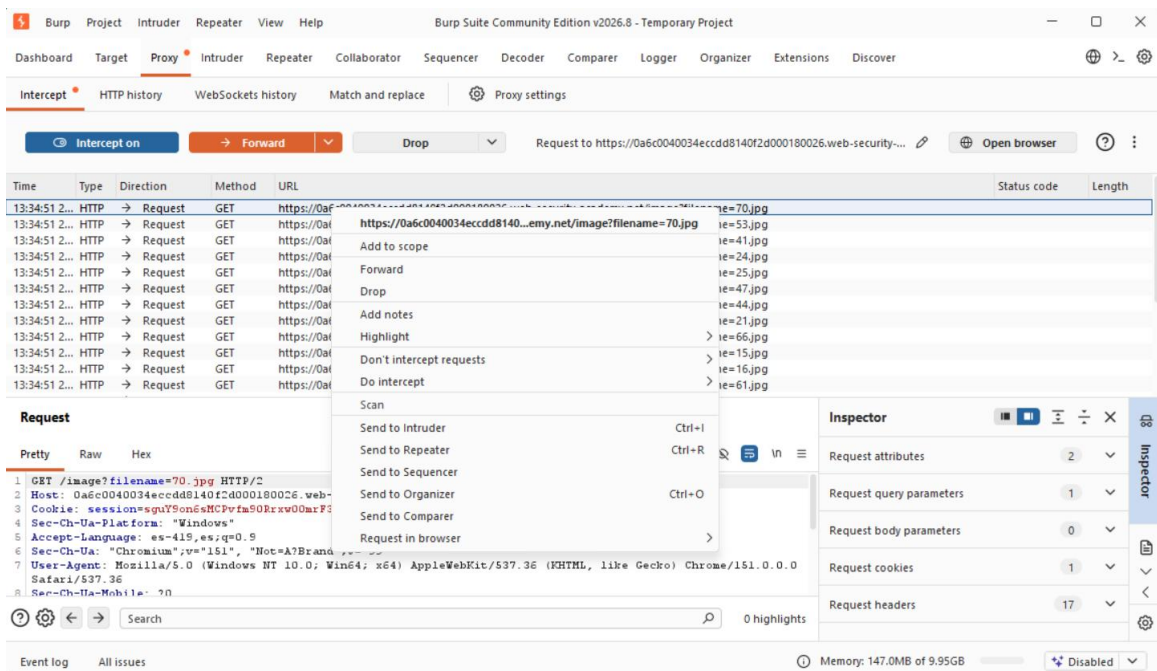


Imagen 9. Se abrirán mas archivos, el que ocuparemos será el que dice “GET /image?filename=70.jpg HTTP/2”. El cual seleccionaremos daremos click y pondremos la opción “Send to Repeater”

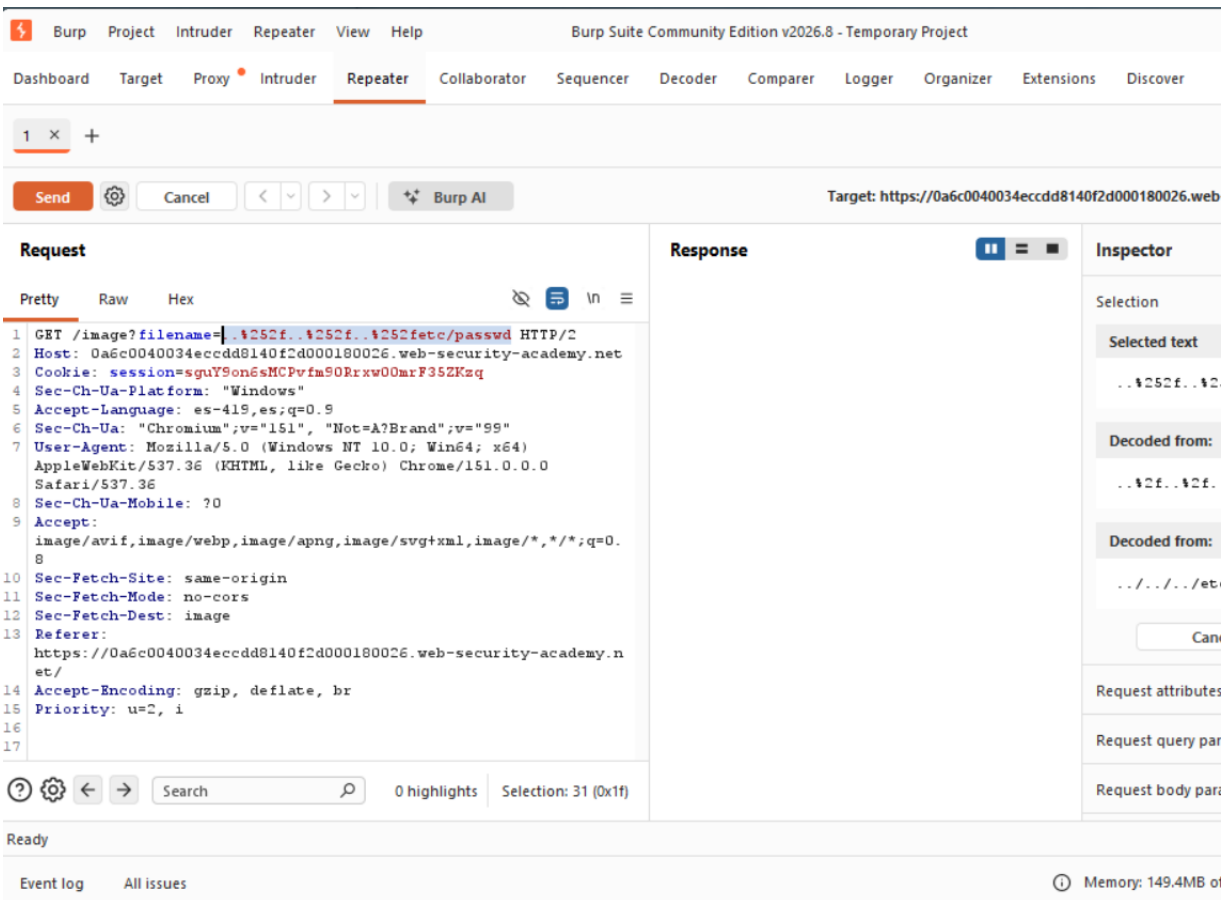


Imagen 11. Nos iremos a la pestaña que se encuentra en la parte superior “Repeater” y la parte que cambiaremos será la seleccionada, en la parte donde estaba “70.jpg” pondremos “..%252f..%252f..%252fetc/passwd” y daremos click en Send que está en la parte de arriba.

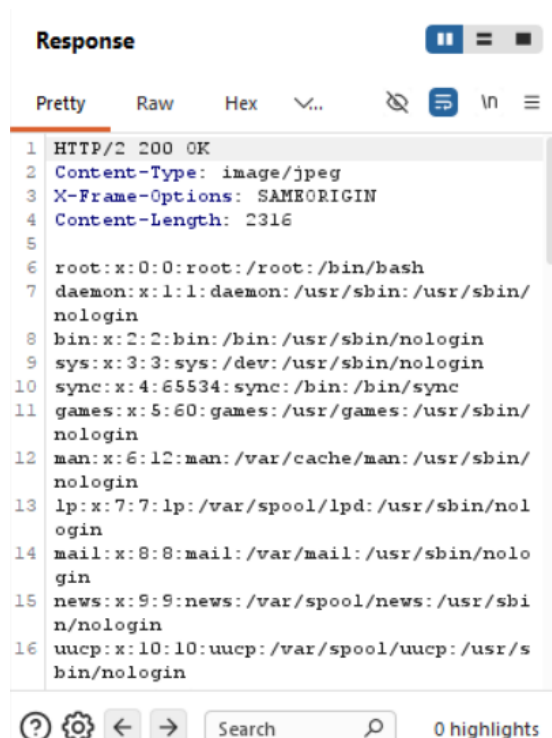


Imagen 13. En el apartado donde dice “Response” aparece el contenido del directorio

Lab: File path traversal, traversal sequences stripped with superfluous URL-decode

PRACTITIONER



LAB



Solved



This lab contains a path traversal vulnerability in the display of product images.

The application blocks input containing path traversal sequences. It then performs a URL-decode of the input before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB



Solution



Community solutions



Imagen 14. En la página del laboratorio aparecerá que ya está resuelto ese laboratorio (Solved √)

4. Mitigaciones Recomendadas

Para solucionar esta vulnerabilidad y prevenir ataques de *Path Traversal*, se recomienda aplicar las siguientes medidas de defensa en profundidad:

1. **Evitar el uso de entradas del usuario en rutas de archivos:** La solución más idónea es no pasar rutas ni nombres de archivos directamente desde el cliente. En su lugar, se deben utilizar identificadores mapeados (p. ej., un ID numérico o un hash) asociados a una lista blanca interna de archivos permitidos.
2. **Sanitización y Validación Correcta:**
 - **Orden de procesamiento:** Siempre se debe realizar cualquier decodificación (URL-decode, HTML decode, etc.) **antes** de aplicar las reglas de validación y sanitización de entrada.
 - **Uso de Rutas Absolutas (Canonicalización):** Resolver la ruta absoluta del archivo mediante funciones del lenguaje (como `canonicalPath` en Java o `realpath` en PHP) y verificar de forma estricta que la ruta resultante comience obligatoriamente dentro del directorio raíz destinado para las imágenes/archivos públicos.
3. **Principio de Mínimo Privilegio:** Configurar el servidor web y los procesos de la aplicación con un usuario de sistema que tenga permisos estrictamente restringidos, evitando que pueda leer archivos sensibles del sistema operativo como `/etc/passwd`.